

Section 08

Industrial Security (Bachelor)



Section 08 – Defense in Depth

Defense in Depth

Lecture Notes

Department of Computer Science

2026-05-17

Industrial Security (Bachelor)

Section 08

Industrial Security (Bachelor)



Section 08 – Defense in Depth

Defense in Depth
Lecture Notes
Department of Computer Science

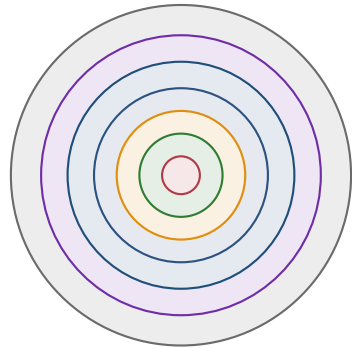
- 1 Layered Controls
- 2 Access and Remote Support
- 3 Patching, Backups, Monitoring

By the end of this section you will be able to

- Apply defense-in-depth across people, process, and technology.
- Design layered controls for an ICS environment.
- Specify secure remote access patterns for vendors.
- Position passive ICS IDS and explain alert triage.

1

Layered Controls



- ■ Policies & procedures
- ■ Physical security
- ■ Network segmentation
- ■ Host hardening
- ■ Application & RBAC
- ■ Data & backups
- ■ Monitoring & IR

Layered

A single failed layer should not equal a successful attack.

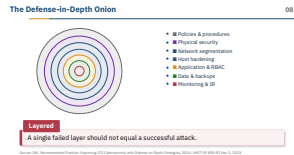
Source: INL, *Recommended Practice: Improving ICS Cybersecurity with Defense-in-Depth Strategies*, 2016 | NIST SP 800-82 Rev. 3, 2023.

2026-05-17

Industrial Security (Bachelor)

└ Layered Controls

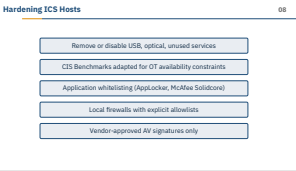
└ The Defense-in-Depth Onion



Defense in depth is not “more controls equals more safety.” It is layered *independence*: each layer must fail in a different way. Make this concrete: if your perimeter firewall, your internal firewall, and your endpoint AV all run the same Windows engine, you have one layer with three logos. The INL onion is useful as a checklist, not as a maturity ladder – you do not earn the inner ring by completing the outer. Ask the room: what makes a layer truly *independent*? The answer involves different vendors, different protocols, and different administrators.

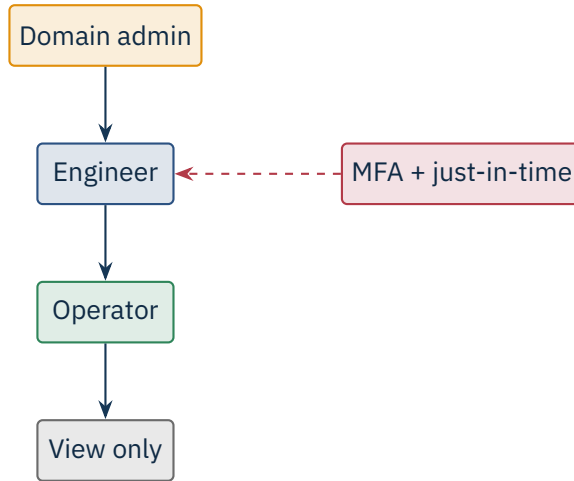
- Remove or disable USB, optical, unused services
- CIS Benchmarks adapted for OT availability constraints
- Application whitelisting (AppLocker, McAfee Solidcore)
- Local firewalls with explicit allowlists
- Vendor-approved AV signatures only

Hardening on a static HMI is a near-perfect fit: the binary set never changes, so application allow-listing (AppLocker, McAfee Solidcore, Carbon Black App Control) actually holds. The catch is the CIS Benchmark line – you cannot apply the IT profile blindly because half of it breaks OPC, breaks WMI for the historian, or kills a vendor’s service account. Build a *tailored* baseline with the integrator and freeze it in the FAT. The AV bullet is the one that bites people: running Defender with cloud-delivered signatures on an engineering workstation can quarantine the PLC programming binary during a download. Always pin to the vendor’s tested signature set.



2

Access and Remote Support

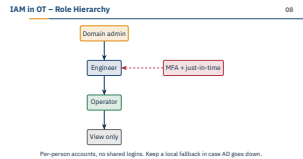


Per-person accounts, no shared logins. Keep a local fallback in case AD goes down.

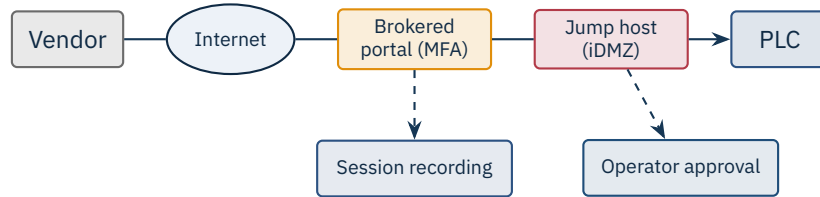
2026-05-17

Industrial Security (Bachelor)
└ Access and Remote Support

└ IAM in OT – Role Hierarchy



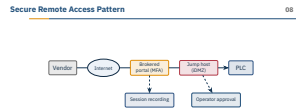
Role separation in OT collapses for one reason: the shared “operator” login on the control-room HMI. Operators rotate shifts, gloves are on, and nobody types a password at 3 a.m. – so an icon on the desktop auto-logs in. That is reality. Push MFA where it works (jump hosts, engineering downloads, AD admin) and accept a kiosk-style HMI session with strong *physical* access control around the room. Just-in-time elevation via something like CyberArk or BeyondTrust beats permanent domain admin every time. Class question: where in this hierarchy would you put a vendor support engineer who shows up twice a year?



2026-05-17

Industrial Security (Bachelor)
Access and Remote Support

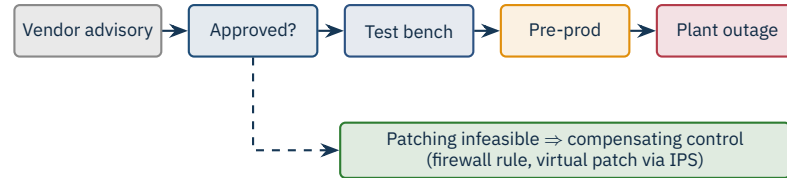
Secure Remote Access Pattern



This is the pattern that actually scales for vendor support. The broker (Cyolo, BeyondTrust Privileged Remote Access, Claroty SRA) terminates the vendor session in the iDMZ; the jump host is the only thing that talks to the PLC, and every keystroke is recorded. The *operator approval* arrow is the cultural change – a vendor cannot just connect, an on-shift operator clicks “allow” for this 30-minute window. War story: a turbine vendor ran a flat IPsec VPN straight into Level 2 for ten years; the day they were breached, the customer’s plant was on the same broadcast domain. Compare this slide with what your plant actually has today.

3

Patching, Backups, Monitoring

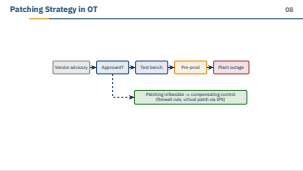


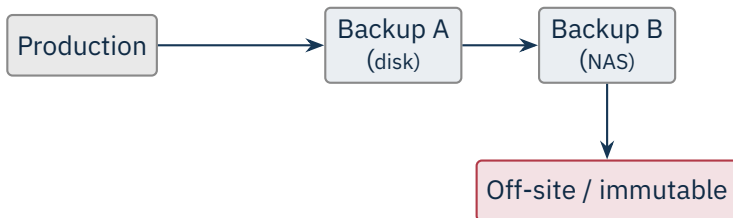
2026-05-17

Industrial Security (Bachelor)
└ Patching, Backups, Monitoring

└ Patching Strategy in OT

The IT instinct is “patch Tuesday.” OT cannot. Vendor-approved is the gate: Siemens, Rockwell, ABB, Honeywell each publish which Microsoft KBs they have validated against their stack, and applying anything else can void support. The test bench and pre-prod stages are where you catch the patch that breaks the OPC server. The *compensating control* branch is the honest answer for the 60% of assets you will never patch – a tighter firewall ACL, a Snort/Suricata signature on the IDS, an IPS rule in front of a vulnerable HMI. Ask the room: how long is acceptable between a CISA advisory and *some* mitigation in your plant?





Back up: PLC programs (with checksums), HMI projects, engineering workstations, historian DB, switch configs. Restore-test regularly.

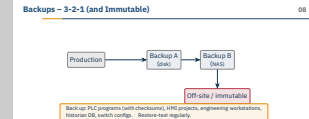
2026-05-17

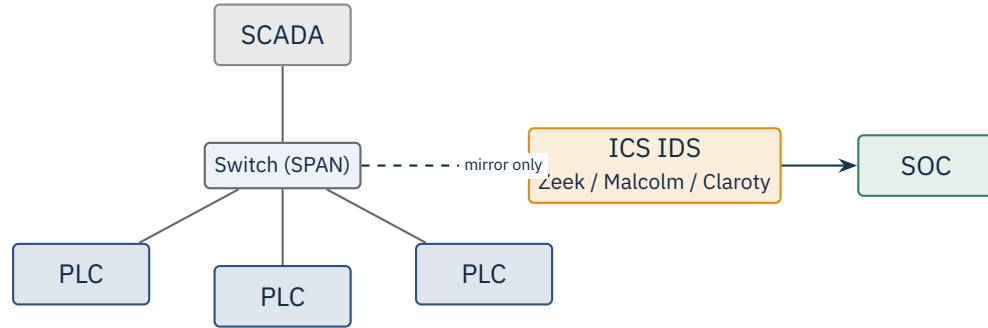
Industrial Security (Bachelor)

└ Patching, Backups, Monitoring

└ Backups – 3-2-1 (and Immutable)

3-2-1 is the floor. The ransomware era added *immutable* – either write-once media or S3 Object Lock / Veeam hardened repository, so an attacker with domain admin cannot wipe the backups. Backing up PLC programs sounds obvious but is routinely missed: the only copy of the ladder logic lives on an engineer's laptop, with no checksum and no version control. Same for HMI projects, historian databases, and switch configs (push to RANCID / Oxidized). The restore-test bullet is where most programs fail – a backup you have never restored is a hope, not a backup. War story: a water utility paid the ransom in 2021 because their tapes had been spinning untested for two years and the catalog was corrupt.





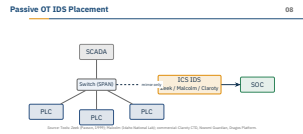
Source: Tools: Zeek (Paxson, 1999); Malcolm (Idaho National Lab); commercial: Claroty CTD, Nozomi Guardian, Dragos Platform.

2026-05-17

Industrial Security (Bachelor)

└ Patching, Backups, Monitoring

└ Passive OT IDS Placement



Passive means *passive* – the IDS sits on a SPAN port or a hardware TAP and never injects a packet. That is the only thing the safety case will accept on Purdue Level 2. The placement detail people miss is which VLAN the SPAN actually carries: I have seen a Nozomi Guardian deployed for a year that was mirroring only the management VLAN, not the process VLAN, so it saw zero Modbus. Verify with `tcpdump -i` before declaring victory. Zeek plus Suricata in Malcolm is a credible open-source stack; Claroty CTD, Nozomi Guardian, Dragos Platform, Cisco Cyber Vision, and Forescout SilentDefense are the commercial options – the differentiator is the protocol dissector library, not the UI.

New device joining (MAC unseen)

Unexpected Modbus function code (e.g. write coil from HMI subnet)

Engineering download outside scheduled change window

Outbound connection from PLC to Internet

PLC mode change (RUN → STOP)

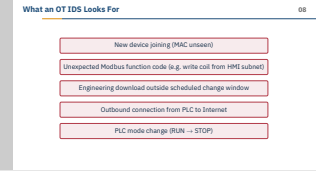
2026-05-17

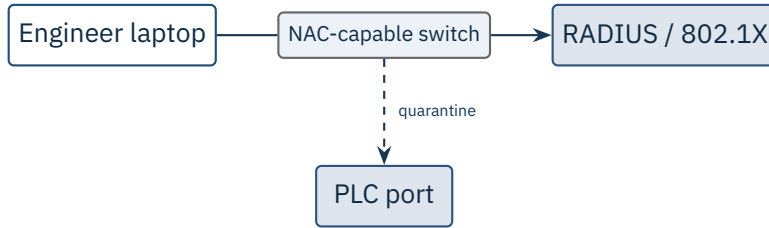
Industrial Security (Bachelor)

└ Patching, Backups, Monitoring

└ What an OT IDS Looks For

These five signatures are the “free” detections you get the day you deploy any OT IDS. Asset discovery alone – a new MAC on the process VLAN – catches the contractor laptop and the rogue access point. The unexpected Modbus function code is the Stuxnet-shaped detection: writes from a subnet that has historically only read. Engineering downloads outside a change window directly maps to your management-of-change process and turns a security alert into a safety conversation. The PLC RUN-to-STOP transition is the one your operations team will care about more than you do – get them subscribed to that alert before you even tune the rest.





Sealing the wall jack

802.1X (with MAC bypass for legacy devices) prevents random laptops from joining the plant LAN. Static PLC ports get MAC pinning.

Source: IEEE 802.1X-2020 | NIST SP 800-92 (logging) | vendors: Cisco ISE, Aruba ClearPass, ForeScout eyeSight.

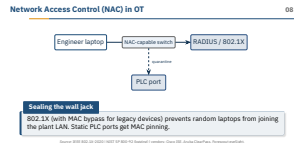
2026-05-17

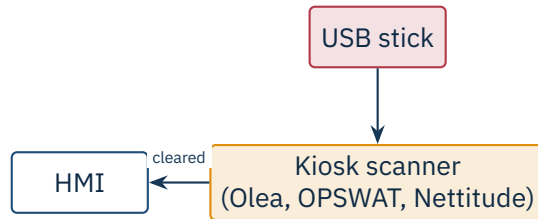
Industrial Security (Bachelor)

└ Patching, Backups, Monitoring

└ Network Access Control (NAC) in OT

802.1X in OT is the long-running argument. The clean version requires a supplicant on every endpoint – and a Siemens S7-1500 does not speak EAP. The workable version is MAC Authentication Bypass with a ForeScout SilentDefense or Cisco ISE policy that pins each PLC port to a known OUI and quarantines anything else. Profile the device before you let it on, not after. The Stuxnet-era lesson is that the attack came in on a USB, but the lateral move was over the flat plant LAN with no port security at all. Ask the room: what is your move when an engineer's laptop fails 802.1X at 2 a.m. during an outage?





One door

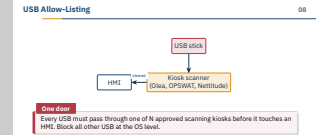
Every USB must pass through one of N approved scanning kiosks before it touches an HMI. Block all other USB at the OS level.

2026-05-17

Industrial Security (Bachelor)
 └ Patching, Backups, Monitoring

└ USB Allow-Listing

“We banned USB” is the common claim – until the vendor walks in with a firmware update on a stick and a deadline. The kiosk approach (OPSWAT MetaDefender, Olea Renegade, Nettitude USB sanitiser) is the realistic compromise: scan with 8+ AV engines, strip macros, re-emit onto a sanitised stick. War story: a refinery had a kiosk in the gatehouse that was bypassed for two years because the operators discovered it stopped scanning when a specific drive letter was already mounted; nobody checked the logs. Block USB at the OS layer via Group Policy or McAfee Device Control *as well*, so the kiosk is the only viable path. Otherwise the policy is theatre.





Send everything, correlate centrally

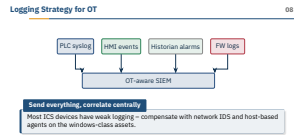
Most ICS devices have weak logging – compensate with network IDS and host-based agents on the windows-class assets.

2026-05-17

Industrial Security (Bachelor)

└ Patching, Backups, Monitoring

└ Logging Strategy for OT



The most expensive misconception in this section is “we have a SIEM.” Splunk, Elastic, or IBM QRadar do not natively parse IEC 60870-5-104, DNP3, or S7Comm – without an OT add-on (Splunk OT Add-on, Dragos Platform feed, Claroty XDR integration) you are correlating Windows event IDs and calling it OT visibility. Send PLC syslog where you can, HMI Windows events, historian alarms, firewall logs, and the IDS metadata into one place. Then build a handful of correlation rules that cross IT and OT signals – e.g. a successful jump-host login followed within five minutes by an engineering download. Without correlation a SIEM is a very expensive log archive.

- Honey-PLCs / honey-HMIs lure scans and exploit attempts.
- Decoy credentials (canary tokens) trip alerts when used.
- Fake assets in DNS / Active Directory.
- False engineering-WS hostnames as tripwires.

Low cost, high signal

A honey-PLC sees *zero* legitimate traffic by design – any hit is a near-certain incident.

2026-05-17

Industrial Security (Bachelor)
└ Patching, Backups, Monitoring

└ Deception in OT

Deception is the cheapest detection control you will deploy. Conpot is the open-source honey-PLC, Thinkst Canary sells a turnkey appliance, and a canary token in a fake `plc_credentials.txt` on the engineering share costs nothing. The point is the false-positive rate: a honey-PLC at `10.20.5.99` sees *zero* legitimate traffic by design, so a single TCP/502 probe is a near-certain incident – no tuning, no triage. Drop a few across each process VLAN, name them in line with your real assets (LINE3-PLC-07), and wire the alert straight to the on-call channel. Bridge: next section we move from defending the plant to detecting and responding when one of these tripwires fires.

- Honey-PLCs / honey-HMIs lure scans and exploit attempts.
- Decoy credentials (canary tokens) trip alerts when used.
- Fake assets in DNS / Active Directory.
- False engineering-WS hostnames as tripwires.

Low cost, high signal

A honey-PLC sees *zero* legitimate traffic by design – any hit is a near-certain incident.

★ Key Takeaway: What to remember from this section

- Defense in depth layers people, process, and technology.
- Hardening and application whitelisting fit well on static HMIs.
- Brokered, recorded, approved remote access beats open VPNs to the plant.
- Passive OT IDS provides visibility without injecting traffic into production.

Close on the independence theme. The four takeaways are the minimum bar; the real test is whether your layers fail independently. If your IDS, your SIEM, and your jump host all log into the same Active Directory with the same admin account, the attacker who owns AD owns all three. Push the class on a final question: pick *one* layer from today's deck that you would add to a brownfield plant first, and justify it on cost-per-detection. Next section we leave prevention behind and look at detection, response, and recovery – because everything in this deck eventually fails, and the question is how fast you notice.

★ Key Takeaway: What to remember from this section

- Defense in depth layers people, process, and technology.
- Hardening and application whitelisting fit well on static HMIs.
- Brokered, recorded, approved remote access beats open VPNs to the plant.
- Passive OT IDS provides visibility without injecting traffic into production.

- Idaho National Lab. *Recommended Practice: Improving Industrial Control System Cybersecurity with Defense-in-Depth Strategies*, 2016.
- NIST SP 800-82 Rev. 3. *Guide to OT Security*, Sep 2023.
- CIS. *CIS Critical Security Controls* v8, 2021.
- CIS Benchmarks (Windows, Linux). Center for Internet Security.
- NIST SP 800-167. *Guide to Application Whitelisting*, 2015.
- NIST SP 800-92. *Guide to Computer Security Log Management*, 2006.
- IEEE 802.1X-2020. *Port-based network access control*.
- Paxson, V. “Bro: A System for Detecting Network Intruders in Real-Time.” *Computer Networks*, 1999 (Zeek origin).
- Open Information Security Foundation. *Suricata IDS*, <https://suricata.io>.
- Idaho National Lab. *Malcolm* network monitor, <https://github.com/idaholab/Malcolm>.
- NIST SP 800-46. *Guide to Enterprise Telework, Remote Access, and BYOD Security*, 2016.
- CISA. *Recommended Cybersecurity Practices for Industrial Control Systems*, 2020.

2026-05-17

Industrial Security (Bachelor)
└ Patching, Backups, Monitoring

└ References – Section 08

References – Section 08	08
• Idaho National Lab. Recommended Practice: Improving Industrial Control System Cybersecurity with Defense-in-Depth Strategies, 2016.	
• NIST SP 800-82 Rev. 3. Guide to OT Security, Sep 2023.	
• CIS. CIS Critical Security Controls v8, 2021.	
• CIS Benchmarks (Windows, Linux). Center for Internet Security.	
• NIST SP 800-167. Guide to Application Whitelisting, 2015.	
• NIST SP 800-92. Guide to Computer Security Log Management, 2006.	
• IEEE 802.1X-2020. Port-based network access control.	
• Paxson, V. "Bro: A System for Detecting Network Intruders in Real-Time." Computer Networks, 1999 (Zeek origin).	
• Open Information Security Foundation. Suricata IDS, https://suricata.io .	
• Idaho National Lab. Malcolm network monitor, https://github.com/idaholab/Malcolm .	
• NIST SP 800-46. Guide to Enterprise Telework, Remote Access, and BYOD Security, 2016.	
• CISA. Recommended Cybersecurity Practices for Industrial Control Systems, 2020.	

End of Section 08

Defense in Depth

Questions and discussion



2026-05-17

Industrial Security (Bachelor)
└ Patching, Backups, Monitoring

End of Section 08

Defense in Depth

Questions and discussion

